

数据库(10)

孙甲松

sunjiasong@tsinghua.edu.cn

电子工程系 信息认知与智能系统研究所

罗姆楼6-104

电话: 13901216180/62796193

2025.11.

第7章 数据库保护

为了保证数据的安全可靠和正确有效，DBMS必须提供统一的数据保护功能，数据保护又称为数据控制，包括：安全性(Security)、完整性(Integrity)、并发控制(Concurrency Control)和数据库恢复(Recovery)这四个方面。

7.1 数据库安全性（第4章）

7.2 数据库完整性（第5章）

7.3 并发控制（第6版第12章，第5版第11章）

7.4 数据库恢复(第6版第11章，第5版第10章)

7.1 数据库安全性

目录

- 7.1.1 计算机系统的安全性
- 7.1.2 计算机系统的安全等级
- 7.1.3 安全性控制方法
- 7.1.4 安全存取控制
- 7.1.5 审计(Audit)
- 7.1.6 数据加密
- 7.1.7 其它安全性保护
- 7.1.8 Oracle的数据库安全性

7.1 数据库安全性

➤ 数据库安全性是指保护数据库，以防止不合法的使用所造成的数据泄露、更改或破坏，无论是有意的还是无意的。主要是针对人的！

➤ 数据库的不安全因素：

1. 非授权用户对数据库的恶意存取和破坏

黑客（**hacker**）和犯罪分子利用木马等在用户登录数据库时盗取用户名和密码，然后假冒合法用户登录，窃取、修改或破坏数据库中的用户数据。需要**DBMS**加强用户身份鉴别、存取控制和视图等技术。

2. 数据库中重要或敏感的数据被泄露

需要**DBMS**提供强制存取控制、数据加密存储和加密传输、审计功能，预防和跟踪非授权用户的入侵。

3. 安全环境的脆弱性

硬件、软件、网络的安全性。需要**trusted**可信软硬件的支撑。

7.1.1 计算机系统的安全性

分为三大类：

- 技术安全类 采用有一定安全性的硬件、软件对系统和数据进行安全保护，保证在无意、恶意攻击时完好无损。
- 管理安全类 软件/硬件故障，意外事故，管理不善
- 政策法规类 政府部门立法，对付垃圾邮件发送者，病毒制造者，黑客等。
- 以下主要讨论技术安全。
- 可信（Trusted）计算机系统的概念和标准，给产品一个安全性指标，供系统使用者参考。

7.1.1 计算机系统的安全性

- 1985年美国国防部（DoD）正式颁布《DoD可信计算机系统评估标准》（Trusted Computer System Evaluation Criteria），简记为: TCSEC或DoD85，TCSEC又称桔皮书。
- 1991年4月美国NCSC（国家计算机安全中心）颁布《可信计算机系统评估标准关于可信数据库系统的解释》（Trusted Database Interpretation），简记为: TDI，即紫皮书。将TCSEC桔皮书扩展到数据库管理系统。TDI紫皮书中定义了数据库管理系统的设计与实现中需满足和用以进行安全性级别评估的标准。

7.1.1 计算机系统的安全性

- TDI/TCSEC 标准将系统划分为四组 (division) 七个等级，从低到高依次是：
D; C(C1,C2); B(B1, B2, B3); A(A1)
- 按系统可靠或可信程度逐渐增高。
- 安全级别之间具有一种偏序向下兼容的关系，即较高安全性级别提供的安全保护要包含较低级别的所有保护要求，同时提供更多或更完善的保护能力。

7.1.2 计算机系统的安全等级

- **D 最小保护 (Minimal Protection)** 基本没有什么安全机制，典型系统：DOS 不设防。
- **C1 自主安全保护 (Discretionary Security Protection)** 能实现用户和数据的分离，进行初级自主存取控制 (DAC)。典型系统：Win95、Win98（以上不能算作安全产品）。
- **C2 受控的存取保护 (Controlled Access Protection)** 安全产品的最低档次，提供受控的存取保护，将C1级的DAC细化，以个人身份注册负责，并实施审计和资源隔离。典型系统：Windows2000, Oracle 7 等。

7.1.2 计算机系统的安全等级

- **B1 标记安全保护 (Labeled Security Protection)**
对系统的数据加以标记，并对标记的主体和客体实施**强制存取控制(MAC)**以及审计等安全机制。达到**B1**级的产品才被认为是真正意义上的安全产品。大型公司或政府部门通常采用这种系统。典型系统：

Trusted Oracle 7, SEVMS VAX 6.0

- **B2 结构化保护 (Structural Protection)** 建立形式化的安全策略模型并对系统内所有主体和客体实施**DAC**和**MAC**。典型系统：

Oracle 9i, Trusted XENIX

7.1.2 计算机系统的安全等级

- **B3 安全域 (Security Domains)** 该级别的TCB(Trusted Computing Base) 必须满足访问控制器的要求, 审计跟踪能力更强, 并提供系统恢复过程。
- **A1 验证设计 (Verified Design)** 提供**B3**级保护的同时给出系统的形式化设计说明和验证, 以确信各安全保护真正实现。

7.1.2 计算机系统的安全等级

- 为满足全球IT市场上互认标准化安全评估结果的需求，CTCPEC（加拿大可信计算机产品评估准则）、FC（美国信息技术安全联邦标准）、TCSEC（美国国防部可信计算机系统评估标准）和ITSEC（欧洲信息技术安全评估准则）的发起组织在1993年开始联合行动，将各自独立的准则合并为单一的、被大家广泛使用的IT安全准则，这一行动被称为通用准则（Common Criteria, CC）项目。
- CC V2.1版在1999年成为ISO标准，2001年被中国采纳为国家标准。
- 目前CC已经基本取代了TCSEC，成为评估信息产品安全性的主要标准。

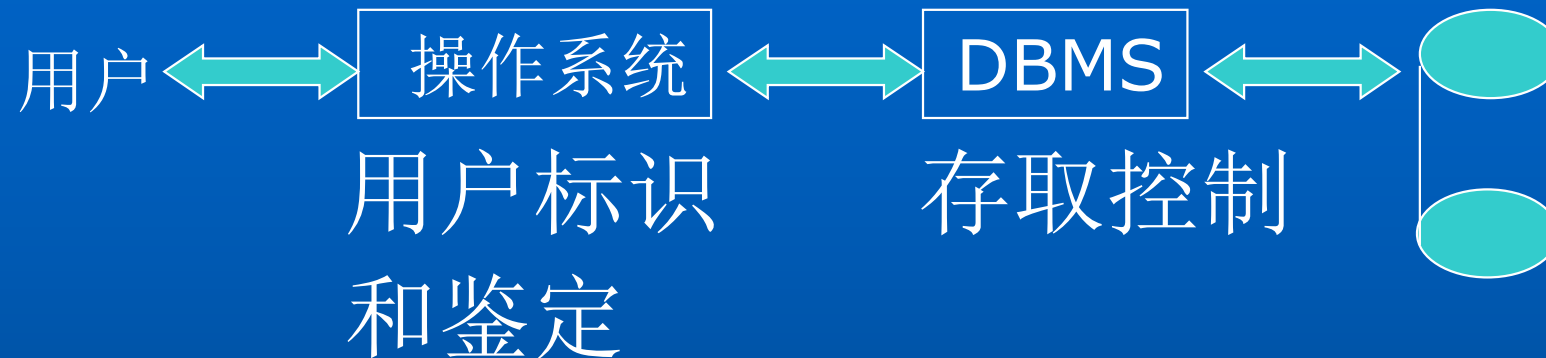
- CC具有结构开放、表达方式通用等特点。
- CC提出了目前国际上公认的表述信息技术安全性的结构，即把对信息产品的安全要求分为功能安全要求和安全保证要求。安全功能要求用以规范产品和系统的安全行为，安全保证要求解决如何正确有效地实施这些功能。安全功能要求和安全保证要求都以“类-子类-组件”的结构表述，组件是安全要求的最小构件块。
- CC的文本有三部分组成，相互依存缺一不可。
- 第一部分是简介和一般模型，介绍术语和基本概念。
- 第二部分是安全功能要求，列出了一系列类、子类和组件。有11大类、66个子类和135个组件构成。
- 第三部分是安全保证要求，列出了一系列保证类、子类和组件，包括7大类、26个子类和74个组件。提出了评估保证级（EAL, Evaluation Assurance Level），共分为7级。

CC评估保证级(EAL)的划分

评估保证级	定义	TESEC安全级别
EAL1	功能测试(functional tested)	D
EAL2	结构测试(structurally tested)	C1
EAL3	系统地测试和检查(methodically tested and checked)	C2
EAL4	系统地设计、测试和复查(methodically designed, tested and reviewed)	B1
EAL5	半形式化设计和测试(semi-formally designed and tested)	B2
EAL6	半形式化验证的设计和测试(semi-formally verified design and tested)	B3
EAL7	形式化验证的设计和测试(formally verified design and tested)	A1

7.1.3 安全性控制方法

➤ 一般安全性控制方法:



➤ 系统或网络的安全性:
合法用户

数据库安全性:
合法用户、授权

➤ 要求操作系统(OS)可靠: **NT, UNIX, XENIX**

➤ 用户身份鉴别: 静态口令鉴别, 动态口令鉴别, 生物特征鉴别 (语音、指纹、虹膜、人脸识别等), 智能卡鉴别

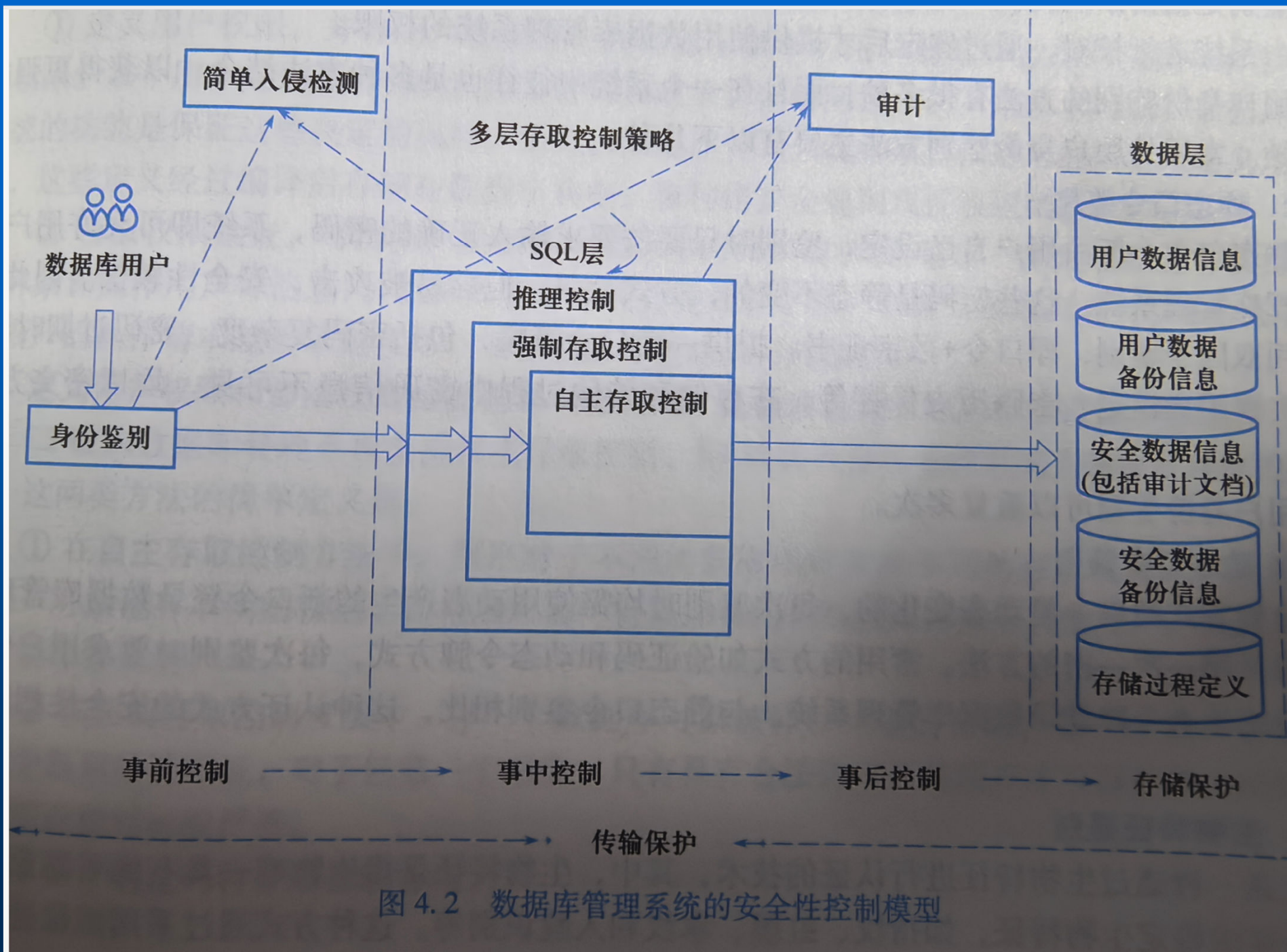


图 4.2 数据库管理系统的安全性控制模型

7.1.3 安全性控制方法

➤ 授权 (Authorization):

授权是借助于数据字典 (DD) 进行:

用户名	数据对象名	允许的操作类型	存取谓词
张三	关系S	SELECT	SD='EE'
张三	关系C	SELECT,UPDATE	SD='CS'
李四	关系S	ALL	空
李四	关系C	ALL	空
王五	关系S	SELECT, UPDATE	Sname='王五'
.....			

7.1.3 安全性控制方法

➤ 授权方式之一：

借助某些工具进行。视图也能起到授权作用

SQL SERVER可以利用授权工具对数据库中每一个关系进行授权（替代**GRANT**命令，权限最终都存入数据字典**DD**中）：

用户名	SELECT	DELETE	UPDATE	INSERT	
张三	√			√	
李四	√	√	√	√	√
王五	√		√		
.....					

SQL Server的安全授权工具

Object Properties - sys_BillFuncList

Permissions

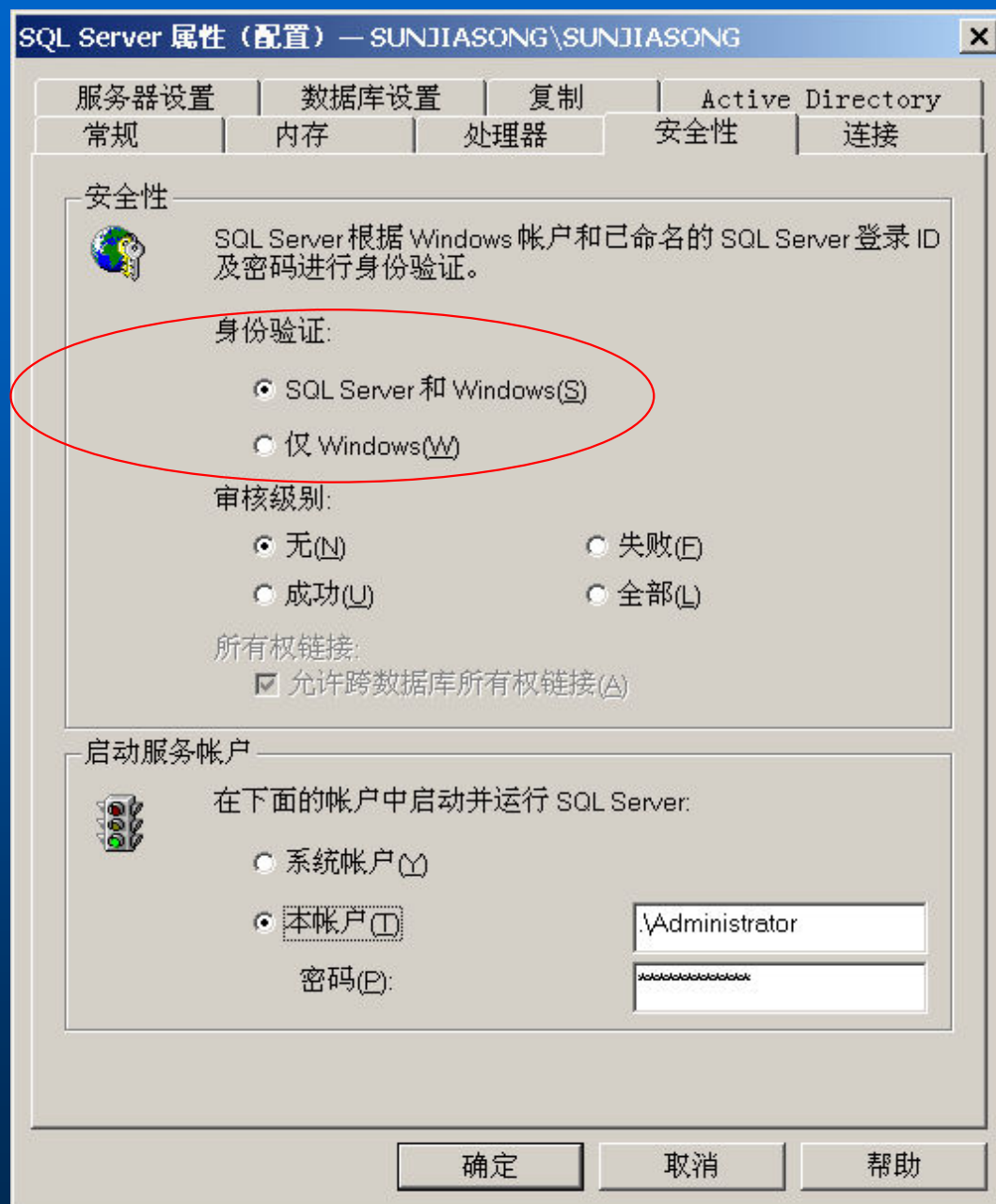
Object: sys_BillFuncList

☒ List all users / user-defined DB roles / public
☐ List only users / user-defined DB roles / public with permissions on this object

Users / DB Roles ...	SELECT	INSERT	UPDATE	DELETE	EXEC	DR
TFC SOPA	☐	☐	☐	☐	☐	☐
TongFangDBA	☒	☒	☒	☒	☐	☐
TongFangOPA	☒	☒	☒	☒	☐	☐
TongFangOPB	☒	☒	☒	☒	☐	☐
TongFangUSR	☒	☐	☐	☒	☐	☐
hf	☐	☒	☒	☒	☐	☐
hi	☐	☒	☒	☒	☐	☐
liuzh	☐	☐	☐	☐	☐	☐
lxq	☐	☐	☐	☐	☐	☐
my	☐	☐	☐	☐	☐	☐
...	☐	☐	☐	☐	☐	☐

确定 取消 应用(A) 帮助

选择系统的安全性身份验证方式:



新建登录:

SQL Server 登录属性 — 新建登录

常规 | 服务器角色 | 数据库访问

 名称(N):

身份验证

☒ Windows 身份验证(W)

域(M):

安全性访问:

☒ 允许访问(G)

☐ 拒绝访问(M)

☐ SQL Server 身份验证(S)

密码(P):

默认设置

指定此登录的默认语言和数据库。

 数据库(D):

语言(L):

确定 取消 帮助

指定数据库:

SQL Server 登录属性 — 新建登录

常规 | 服务器角色 | 数据库访问

指定此登录可以访问的数据库(S)

许可	数据库	用户
☐	Northwind	
☐	master	
☐	model	
☐	msdb	
☐	pubs	
☐	tempdb	

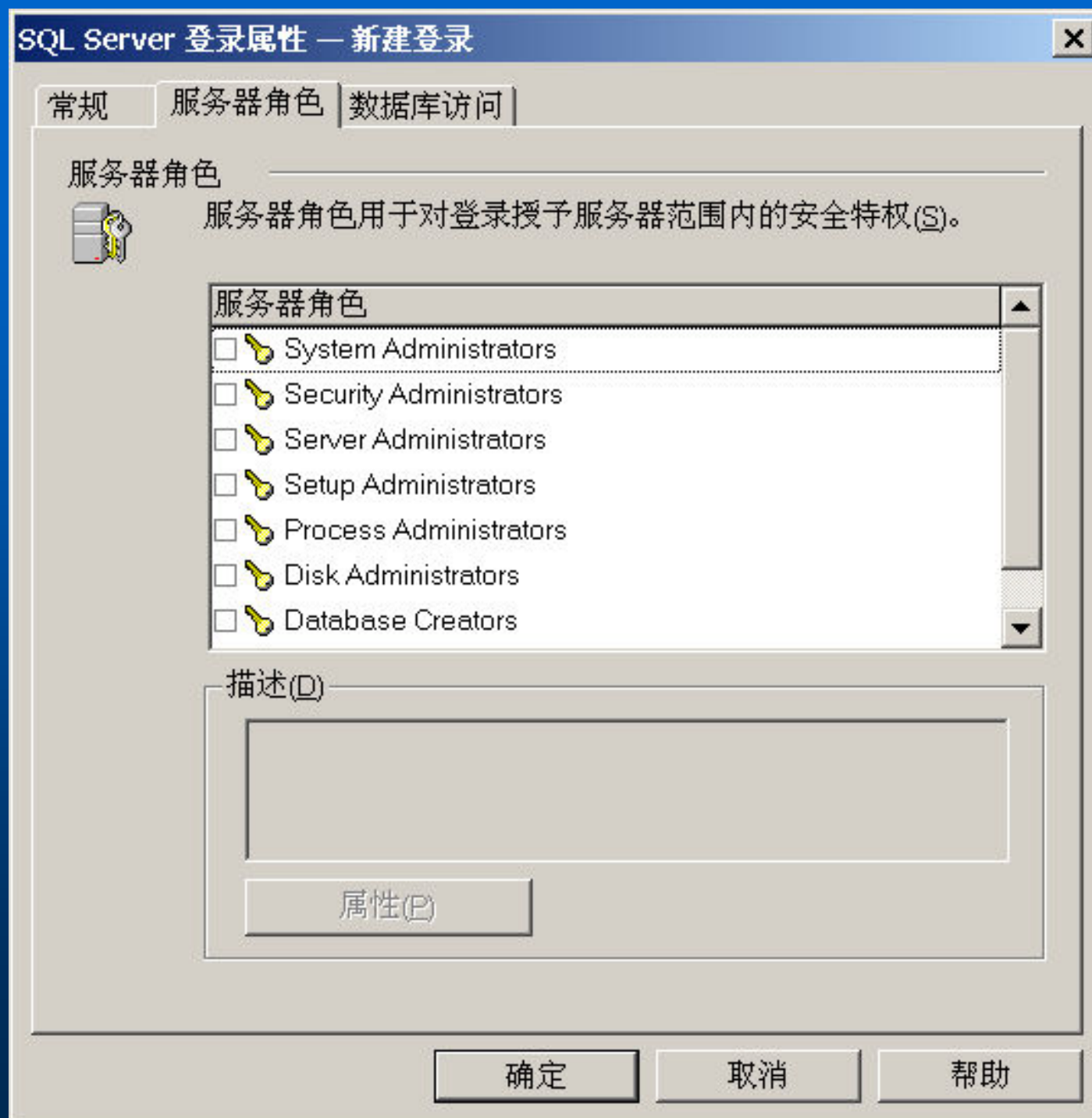
“Northwind”的数据库角色(D):

数据库角色中允许

属性(P)

确定 取消 帮助

指定角色:



7.1.3 安全性控制方法

➤ 授权方式之二：

用SQL的控制命令GRANT/REVOKE对数据库中每一个关系进行授权：

GRANT SELECT,INSERT ON S TO 张三

GRANT ALL PRIVILEGE ON S TO 李四

REVOKE INSERT ON S TO 张三

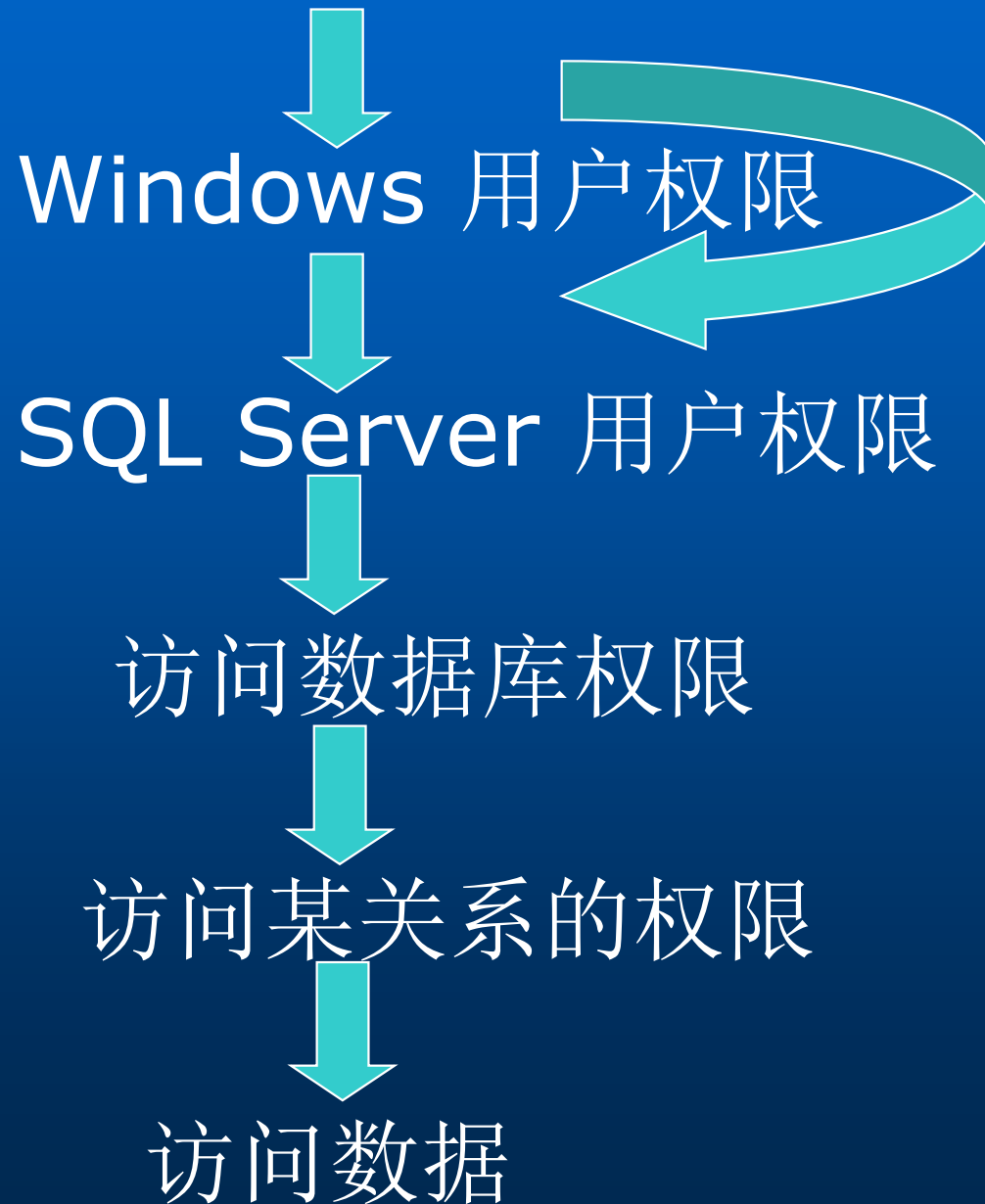
权限都存入数据字典DD中，任何对关系的访问，首先要查DD，看是否有权做相应的动作。

(1) 授权数据对象范围越小，越灵活，但系统越复杂，开销越大。

(2) 授权对象能否与数据值有关。

7.1.3 安全性控制方法

➤ SQL Server 2008访问权限检查流程:



7.1.4 安全存取控制

➤ 自主存取控制 (DAC)

— Discretionary Access Control

SQL语言中通过GRANT/REVOKE命令，系统通过用户权限，自主对数据存取进行控制。

➤ 强制存取控制 (MAC)

— Mandatory Access Control

是用户不能直接感知或不能自我进行控制的。
适用于对数据或文件有严格而固定密级分类的部门。所管理的全部实体分为两大类：

- { 主体（用户、进程等）
- { 客体（数据、文件等）

7.1.4 安全存取控制

- 为每一个实体指定一个敏感度标记(Label)。
- 只有当: $\text{Label}_{\text{主体}} \geq \text{Label}_{\text{客体}}$ 时才可以访问客体!

DAC和MAC共同构成某些DBMS的安全机制:



7.1.4 安全存取控制

- 支持自主存取控制(DAC)的DBMS大致属于C级。
- 支持强制存取控制(MAC)的DBMS则可以达到B1级。
- 存取控制仅是安全性标准的一个重要方面（即安全策略方面）但不是全部。
- 为了使DBMS达到一定的安全级别，还需要在其它几个方面提供相应的支持。
- 例如审计功能就是DBMS达到C2以上安全级别必不可少的一项指标。

7.1.5 审计(Audit)

- 按照TDI/TCSEC标准中安全策略的要求，审计功能是DBMS达到C2以上安全级别必不可少的一项指标。
- 因为任何系统的安全保护措施都不是完美无缺的，蓄意盗窃、破坏数据的人总是想方设法打破控制。
- 审计功能把用户对数据库的所有操作自动记录下来放入审计日志（Audit Log）中。
- DBA可以利用审计跟踪的信息，重现导致数据库现有状况的一系列事件，找出非法存取数据的人、时间和内容等。

7.1.5 审计(Audit)

- 审计通常是很费时间和空间的，所以DBMS往往都将其作为可选特征，允许DBA根据应用对安全性的要求，灵活地打开或关闭审计功能。
- 审计功能一般主要用于安全性要求比较高的部门。

7.1.6 数据加密

- 对于高度敏感性数据，如财务数据、军事数据、国家机密等，除前面所讲的安全性措施外，还可以采用数据加密技术。
- 数据加密是防止数据库中数据在存储和传输中失密的有效手段。加密的基本思想是根据一定的算法将原始数据（术语为明文，**Plain text**）变换为不可直接识别的格式（术语为密文，**Cipher text**），从而使得不知道解密算法的人无法获知数据的内容。
- 加密方法主要有两种：替换方法，置换方法

7.1.6 数据加密

- 替换方法：该方法使用密钥（**Encryption Key**）将明文中的每一个字符转换为密文中的一个字符甚至多个字符。
- 置换方法：该方法仅将明文的字符按不同的顺序重新排列。
- 单独使用这两种方法的任意一种都是不够安全的。但是将这两种方法结合起来就能提供相当高的安全程度。采用这种结合算法的例子是美国1977年制定的官方加密标准：数据加密标准（**Data Encryption Standard**，简称**DES**）。有关DES密钥加密技术及密钥管理问题等因为时间所限，这里不再讨论。

7.1.7 其它安全性保护

- 为满足较高安全等级数据库管理系统的安全性保护要求，在自主存取控制和强制存取控制之外，还有：
- 推理控制(**inference control**)
 - 避免用户利用其能够访问的数据推知更高密级的数据。
 - 常用的方法有：基于函数依赖的推理控制，基于敏感关联的推理控制等。
- 隐蔽信道(**covert channel**)
 - 比如反复用insert插入重复值检测。
- 数据隐私 (**data privacy**)
 - 控制不愿被他人知道或他人不便知道的个人数据的能力。

7.1.8 Oracle的数据库安全性

Oracle数据库安全性

为何选择Oracle？

从一开始，Oracle就提供了业界最先进的技术来保护存储在数据库中的数据。

Oracle提供了全面的安全性解决方案组合来保护数据隐私，防范内部威胁，并确保遵守法规。

借助Oracle强大的数据库活动监控和分块、授权用户和多要素访问控制、数据分类、透明的数据加密、统一的审计和报表编制、安全的配置管理和数据屏蔽等强大功能，用户无需对现有应用程序做任何改变即可部署可靠的数据安全性解决方案，从而节省时间和金钱。

在安全性方面处于行业领先地位

- KuppingerCole：Oracle数据库安全性产品报告
- Forrester公司：数据屏蔽
- 在第三方安全标准评估中处于领先地位
- 充满信心地进行部署：客户成功案例
- 前所未有的SQL注入攻击保护：Oracle数据库防火墙——您的第一道防线

Oracle数据库安全性产品

- Oracle高级安全性
- Oracle Audit Vault
- Oracle标签安全性
- Oracle配置管理
- Oracle安全备份
- Oracle数据库防火墙
- Oracle Database Vault
- Oracle数据屏蔽
- Oracle全面回忆

- Oracle企业管理器12c引入了**数据库安全状态显示板**，以使管理员能全面了解企业内部数据库的安全措施。这个新的状态显示板还提供了一个易于使用的集中式界面，以管理全面的Oracle数据库安全解决方案。
- Oracle企业管理器12c中所纳入的**Oracle数据屏蔽软件包**以及新的敏感应用数据发现工具是全面的Oracle数据库安全解决方案系列的组成部分，对

Oracle Advanced Security

Oracle Audit Vault(审计保险库)

Oracle 数据库防火墙

Oracle Database Vault(数据库保险库)

起到了补充作用。

- 很多企业拥有数百甚至数千个需要管理的数据库。这些企业都在努力判别，哪些数据库包含着敏感和受到法规保护的信息。
- 为了进一步帮助管理员保护关键数据库，Oracle企业管理器12c引入了新的**Oracle数据屏蔽软件包**（Oracle Data Masking Pack），以发现敏感和受保护的应用数据，并对其建模。
- 这个工具可用来发现敏感数据，例如：信用卡号码、社会保障号码、生日等需要屏蔽、加密或审计的敏感数据。

➤ 最新版**Oracle数据屏蔽软件包**（Oracle Data Masking Pack）包括如下新功能：

(1) 与Oracle真正应用测试集成，以抓取和屏蔽生产数据库的工作负载，从而在非生产环境中安全使用；

(2) 与Oracle测试数据管理软件集成，以屏蔽生产数据库的子集；

(3) 利用Oracle数据库网关，屏蔽存储在非Oracle数据库中的数据；

(4) 可逆格式，保留屏蔽；

(5) 更多的内置屏蔽规则和模板。

一个基于Oracle的财务系统的安全性设计

4.4 安全性设计

1 软件架构设计

- 身份鉴别机制：统一身份认证
- 访问控制机制：基于RBAC的访问控制，Filter过滤请求
- 安全审计机制：详细可追溯的日志

2 软件开发安全与代码检测

3 运行环境安全

基于角色的访问控制（**RBAC**）是实施面向企业安全策略的一种有效的访问控制方式。

7.2 数据库完整性(Integrity)

- 指数据库中数据的正确性和相容性。DBMS必须提供一种机制保证数据库的完整性(Integrity)。

{ 接收完整性约束条件 作为模式的一部分存入数据库
用条件进行完整性检查

- 防止错误信息的输入/输出，防范不合语义的数据！完整性与安全性不同，但密切相关。对某一种问题，某种机制可起到共同的作用。

7.2 数据库完整性(Integrity)

目 录

7.2.1 完整性约束条件

7.2.2 完整性控制

7.2.3 Oracle的数据库完整性

7.2.4 断言

7.2.5 触发器

7.2.1 完整性约束条件

➤作用对象可以是关系、元组、列(属性)三种。

(一) 值的约束和结构的约束

1. 对属性数据值的约束 属性的数据取值类型、范围、精度等的规定：

- 是否允许空 (NULL/NOT NULL)
- 职工年龄：16~60 (check约束)
- 工资： ≥ 789 (check约束)

2. 数据之间联系的约束

- { 同一关系的不同属性之间联系的约束
函数依赖，多值依赖，码唯一非空等
- { 不同关系的属性之间的联系的约束

7.2.1 完整性约束条件

- 参照完整性，值的相等、关联来体现
-  一个关系中某属性的值集是另一个关系中某属性值集的子集。 例如：
C(CNO,CN,CPNO)中，CPNO的值集是CNO值集的真子集
- 属性数据相互关联， x 是级别， y 是工资，
当 $x_1 > x_2$ 时，必须 $y_1 > y_2$ 。
- (二) 静态约束和动态约束
- 静态约束：指数据库每一个确定状态的数据应该满足的约束条件。以上值的约束和结构的约束都是静态约束。

7.2.1 完整性约束条件

- 动态约束：指数据库从一个状态转换为另一个状态时，新、旧值之间应满足的约束条件。
- 例如：涨工资时，新值不能小于旧值
- 动态约束分为：
 1. 立即执行约束
 2. 延迟执行约束

7.2.2 完整性控制

- 立即执行约束（Immediate Constraints）：指执行事务（每次操作）时，对事务中某一更新语句执行完后马上对此数据应满足的约束条件进行完整性检查。（事务中可能有多个更新语句）不满足则不执行此语句！
- 延迟执行约束（Deferred Constraints）：指整个事务执行完后，再对事务中每一个更新语句所访问的数据应满足的约束条件进行完整性检查。（事务中可能有多个更新语句）
- 满足完整性限制方能提交执行此事务。否则整个事务都会被拒绝！

7.2.3 Oracle的数据库完整性

- 实体完整性：提供了PRIMARY KEY子句，与指定NOT NULL含义不同。

Create Table S

```
( SNO NUMBER(8),  
  Sname Varchar(20),  
  Sage NUMBER(8),  
  constraint PK_SNO PRIMARY KEY(SNO))
```

- PK_SNO是 SNO的约束名

Create Table SC

```
( SNO NUMBER(8),  
  CNO NUMBER(2) ,  
  Grade NUMBER(2),  
  constraint PK_SC PRIMARY KEY(SNO,CNO))
```

7.2.3 Oracle的数据库完整性

- 参照完整性：提供了FOREIGN KEY 子句和REFERENCES子句。

Create Table S

```
( SNO NUMBER(8),  
  Sname Varchar(20),  
  Sage NUMBER(8),  
  Sdept NUMBER(8),  
  constraint FK_DEPTNO FOREIGN KEY(Sdept)  
    REFERENCES DEPT(DEPTNO))
```

- S参照DEPT，SDEPT是S的外码，对应DEPT中的主码DEPTNO。

7.2.3 Oracle的数据库完整性

- 用户定义的完整性：提供了NOT NULL(非空)、UNIQUE(列值唯一)和CHECK(取值范围)子句。

Create Table S

```
( SNO NUMBER(8) Constraint S1 NOT NULL,  
  Sname Varchar(20) Constraint S2 UNIQUE,  
  Sage NUMBER(8) constraint S3 CHECK  
    (Sage>=16 AND Sage <=60),  
  Sdept NUMBER(8),  
  constraint FK_DEPTNO FOREIGN KEY(Sdept)  
    REFERENCES DEPT(DEPTNO) )
```

这里，S1、S2、S3、FK_DEPTNO是S的完整性限制条件。

7.2.3 Oracle的数据库完整性

➤用户定义的完整性:

Create Table SC

```
( SNO NUMBER(8),  
  CNO NUMBER(2) ,  
  Grade NUMBER(2) constraint S4 CHECK  
    (Grade >=0 AND Grade <=100),  
  constraint PK_SC PRIMARY KEY(SNO,CNO))
```

这里，S4、PK_SC都是选修关系SC的完整性限制条件。

完整性限制条件可以在表建立后删除或修改。

7.2.4 断言

- 用户可以用SQL语言中的CREATE ASSERTION生成具有一般性约束条件的断言，一般格式为：

CREATE ASSERTION <断言名><CHECK 字句>

例如，限制数据库课程最多200名学生选修。

```
CREATE ASSERTION ASSE_SC_DB_NUM  
CHECK (200 > (SELECT count(*)  
FROM C,SC  
WHERE SC.SNO=C.CNO  
AND C.NAME='数据库'));
```

当学生选课时，每插入一个元组，ASSE_SC_DB_NUM断言都会被触发检查，若已经达到200人，CHECK将返回假，对选课关系SC的插入操作就会被拒绝。

7.2.5 触发器

- **触发器(trigger)**是用户定义在关系表上的一类由事件驱动的特殊过程。又叫事件-条件-动作**ECA**规则。触发器类似于约束，但是比约束更加灵活，可以实施更为复杂的检查和操作，具有更精细和更强大的数据控制能力。包括行级触发器、语句级触发器等。
- 触发器在**SQL-99**之后才引入**SQL**国际标准中，因此现在各家的触发器语法基本各不相同、互不兼容。
- 大致的语法形式：

```
CREATE TRIGGER <触发器名>
{BEFORE | AFTER} <触发事件> ON <表名>
REFERENCING NEW | OLD ROW AS <变量>
FOR EACH {ROW | STATEMENT}
[WHEN <触发条件>] <触发动作体>
```

时间所限，不再举例，可参阅第6版164-165页的几个例子。